IS 414:
IS SECURITY & CONTROLS

Dr. Taylor Wells

INCIDENT RESPONSE

DEFINITIONS

- Event
  - *Observable occurrence in our IT infrastructure*
- Incident (ISO 27001)
  - *Any event which is not part of the standard operation of a service and which causes, or may cause, an interruption to, or a reduction in, the quality of that service.*

ISO 27001

Definitions

- Computer Security Incident Response Team (CSIRT)
  - *Responsible for responding to security incidents*
  - *Usually cross-functional*
  - *There are some related terms that are mostly used synonymously*
    - Computer Emergency Response Team (CERT)
    - Computer Incident Response Team (CIRT)
- Security Operations Center (SOC)
  - *Formal organization for monitoring and defending against security threats*

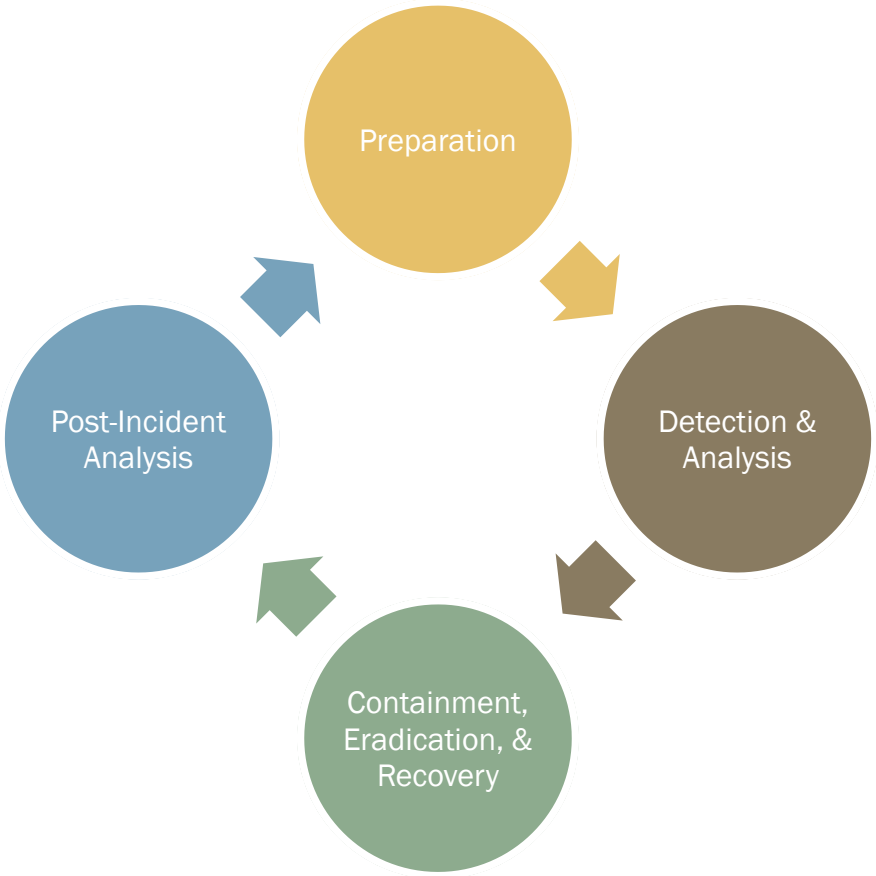
A FEW INDUSTRY STANDARDS

- Expectations for Computer Security Incident Response (IETF RFC 2350)
  - *https://tools.ietf.org/html/rfc2350*
- **Computer Security Incident Handling Guide (NIST 800-61)**
  - *https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final*

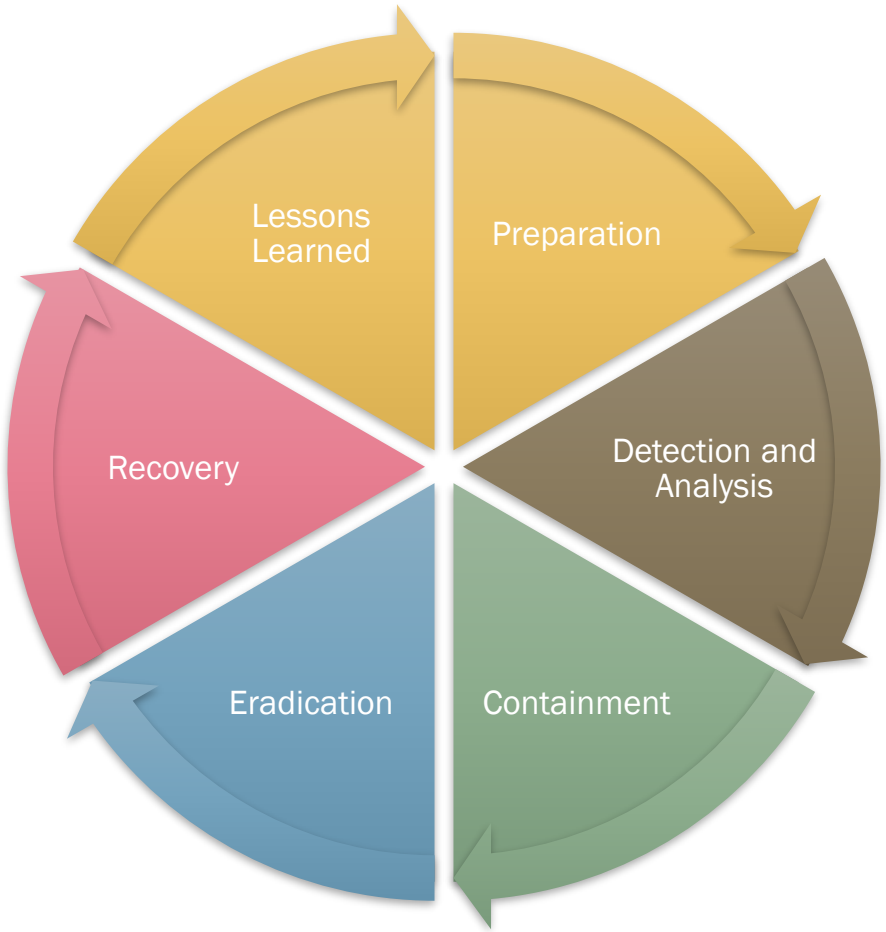
Types of Response

- Technical response
- Public relations response
- Legal response

NIST Incident Response Lifecycle Phases

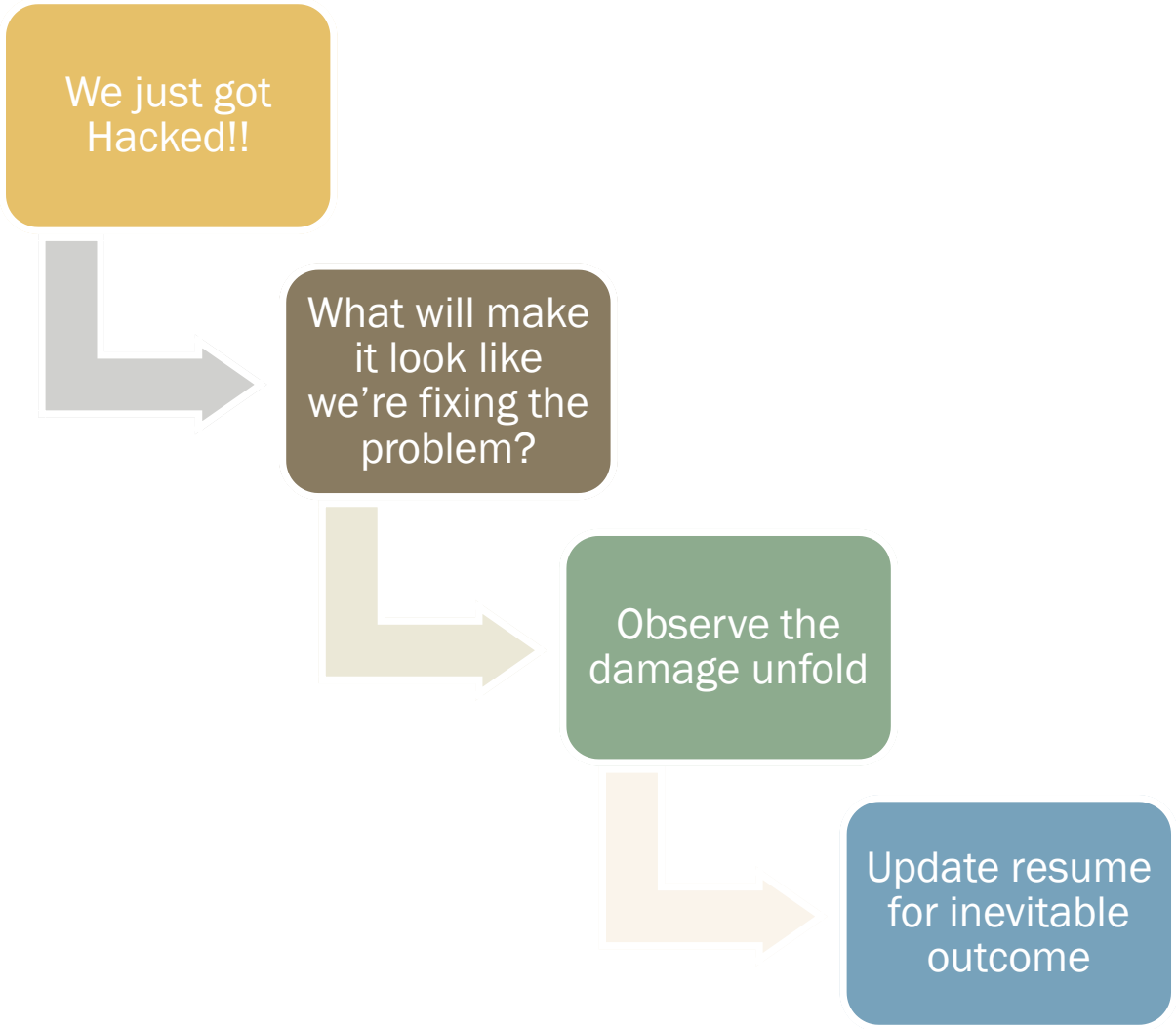


NIST Incident Response Lifecycle Phases



PREPARATION

Typical Incident Response



Preventing Incidents

- Apply many of the defensive security tools/techniques/practices we have learned already:
  - *Firewalls*
  - *Network segmentation*
  - *Patching*
  - *Least privilege designs*
  - *Network logging*
  - *Host-based logging*
  - *Planning*
  - *User training*
  - *Risk assessments*

Establishing an Incident Response Capability

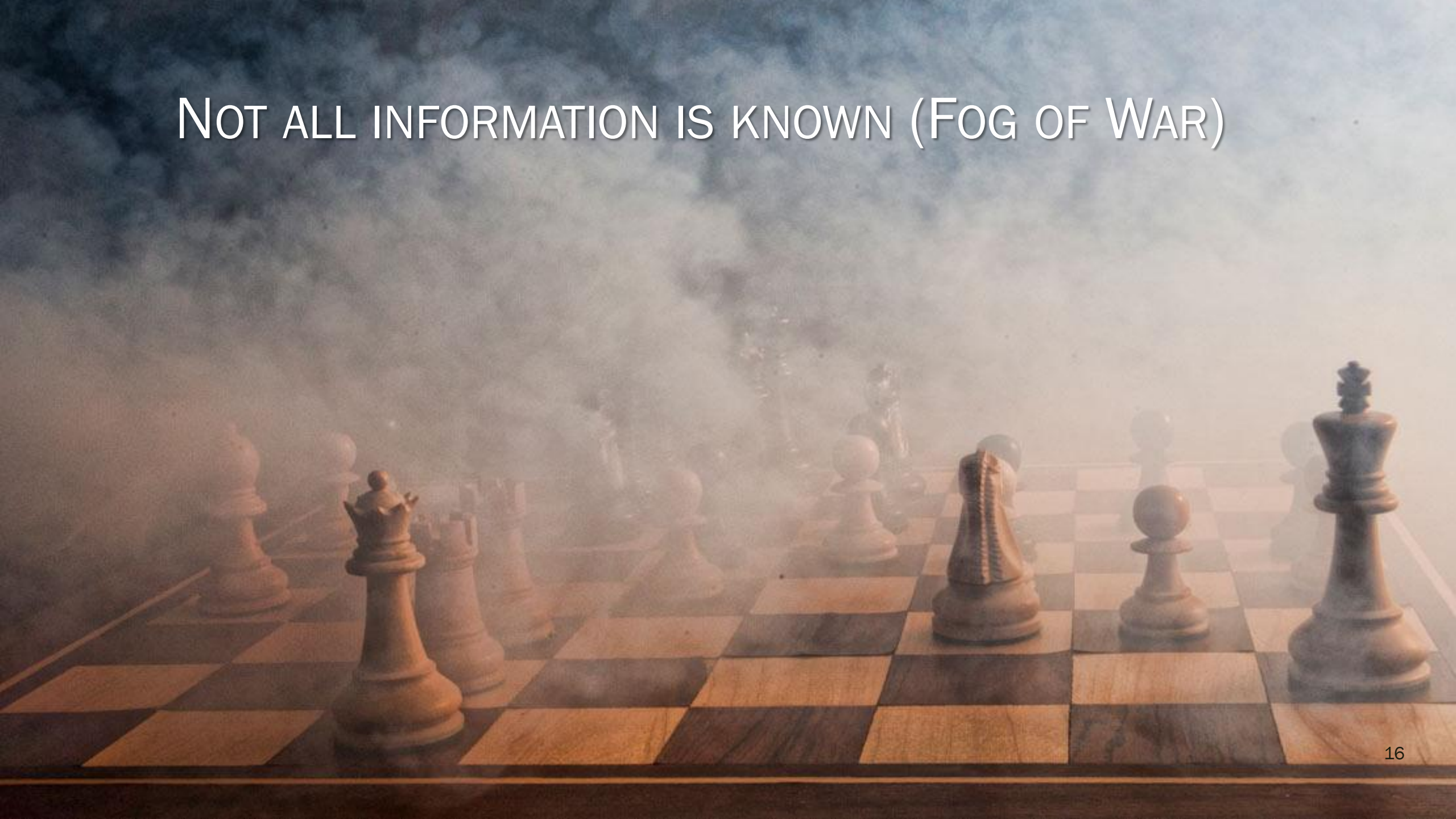
- A managerial/organizational issue
- Complex undertaking
- Takes planning and organization
- Goal is to mitigate risk
  - *What is a "major incident"?*

When a major Incident occurs …

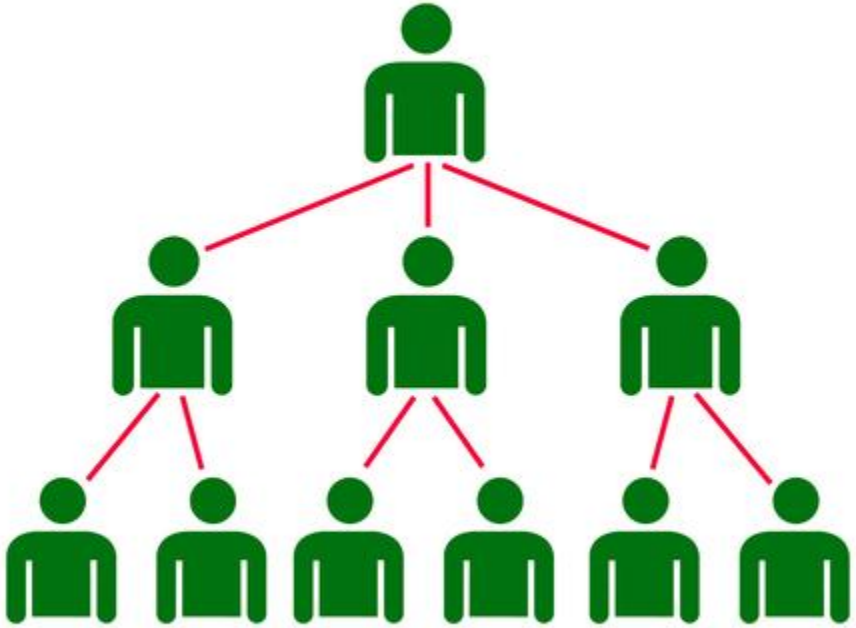
People May Panic

Or at a minimum will be stressed

Not all information is known (Fog of War)



Useful to borrow concepts from the military like Chain of Command



"He who fails to plan is planning to fail."

What to plan?

- The CSIRT
- Communication strategy
  - *Internal*
  - *External (including law enforcement and PR)*
- Response to common attacks
- Policies and Procedures

ROOTKIT HACKED SERVER

NIST Incident Response Lifecycle Phases

DETECTION & ANALYSIS

Signs of an Incident

- Precursors vs. Indicators
  - *Precursors show event may happen in future (e.g., a vulnerability in a scan)*
  - *Indicators show something happened or is happening now*

Example Precursors and Indicators

- Web server logs getting scanned
- A new vulnerability is announced
- Receive intelligence of an upcoming attack
- Intrusion Detection System alert that DB server is being attacked
- Anti-Virus detects malware
- System administrator sees something weird
- Host configuration changes and the change is logged
- Failed logins (application, system)
- Deviation in network traffic
- And many more …

Intrusion Identification Data Sources

- IDS, IPS
- SIEM (analytics)
- Anti-Virus / Anti-Malware
- File integrity checks (hashing)
- Third party monitoring software (e.g., FireEye)
- Logs
- People
  - *Internal*
  - *External*

Locard’s Exchange Principle

- *Everything leaves a trace / evidence*

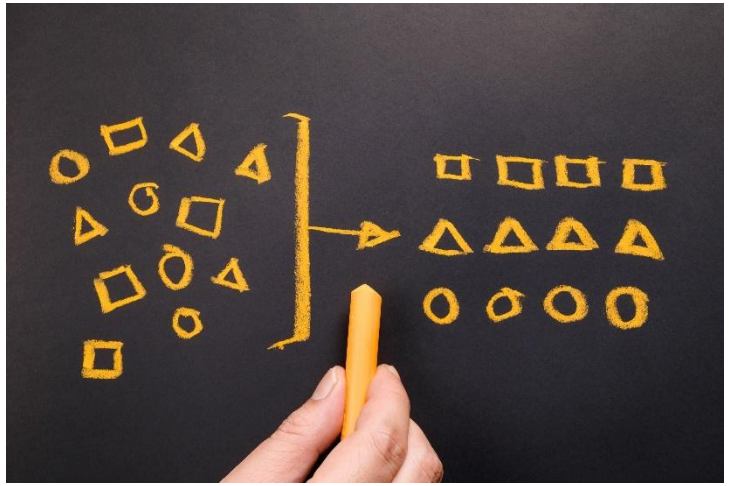
CONTAINMENT, ERADICATION, & RECOVERY

CLASSIFICATION OF INCIDENT

- https://www.first.org/resources/guides/csirt_case_classification.html

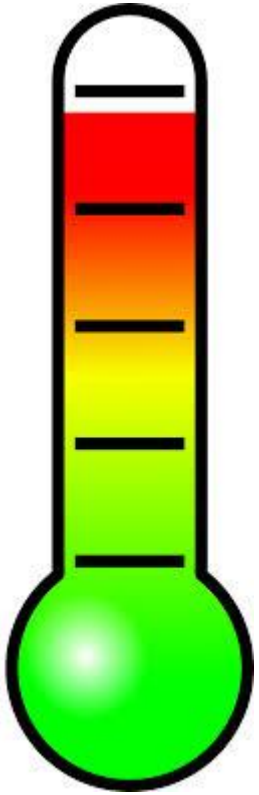
CATEGORY

- Denial of Service
  - *DOS or DDOS*
- Compromised Information
  - *Disclosure of sensitive corporate information or intellectual property*
- Compromised Asset
  - *Compromised host, network device, user account, application*
  - *Malware, root account, rootkit, etc.*
- Unlawful Activity
  - *Theft, Fraud, Computer Safety*



- Internal Hacking
  - Suspicious activity originating from inside the network, excluding malware
- External Hacking
  - Suspicious activity originating from outside the network, excluding malware
- Email
  - Spoofed email, spam, phishing
- Malware
- Policy Violation

CRITICALITY



- Incident affecting critical systems
  - *Potential to impact revenue or customers*
  - *Active hacking, compromised critical asset, virus outbreak, etc.*
  - *Initial response time: 60 minutes*
- Incident affecting non-critical systems
  - *Not revenue or customer impacting*
  - *Time-sensitive employee investigations*
  - *Policy violations, unauthorized access, compromised asset, inactive hacking*
  - *Initial response time; 4 hours*
- Possible incident affecting non-critical systems
  - *Employee investigations not time sensitive, longer-term investigations*
  - *Email, forensics request, policy violation*
  - *Initial response time: 48 hours*

SENSITIVITY

- Helps define the “need to know” and who should be in the loop
- Level 1: Extremely sensitive
  - *Forensics request, destruction of property, unlawful activity, compromised information, etc.*
  - *Informed: CSIRT, Management*
    - Computer Security Incident Response Team
- Level 2: Sensitive
  - *Hacking, unauthorized access*
  - *Informed: CSIRT, Management, System owners, Operations*
- Level 3: Not sensitive
  - *Denial of service, virus, email*
  - *Informed: Employees can be informed as well of isolated infections*

Inform appropriate entities

- Thorough planning should help in identifying who should be informed
- A senior manager should sponsor the CSIRT
  - *CISO, CIO, Legal counsel, etc.*
  - *Notify them when declaring an incident*
    - Email
    - Phone call or visit for the critical incidents
- Local or organizational incident-handling team
- Impacted business unit

- Start tracking the incident
  - *Utilize an incident tracking system*

CONTAINMENT

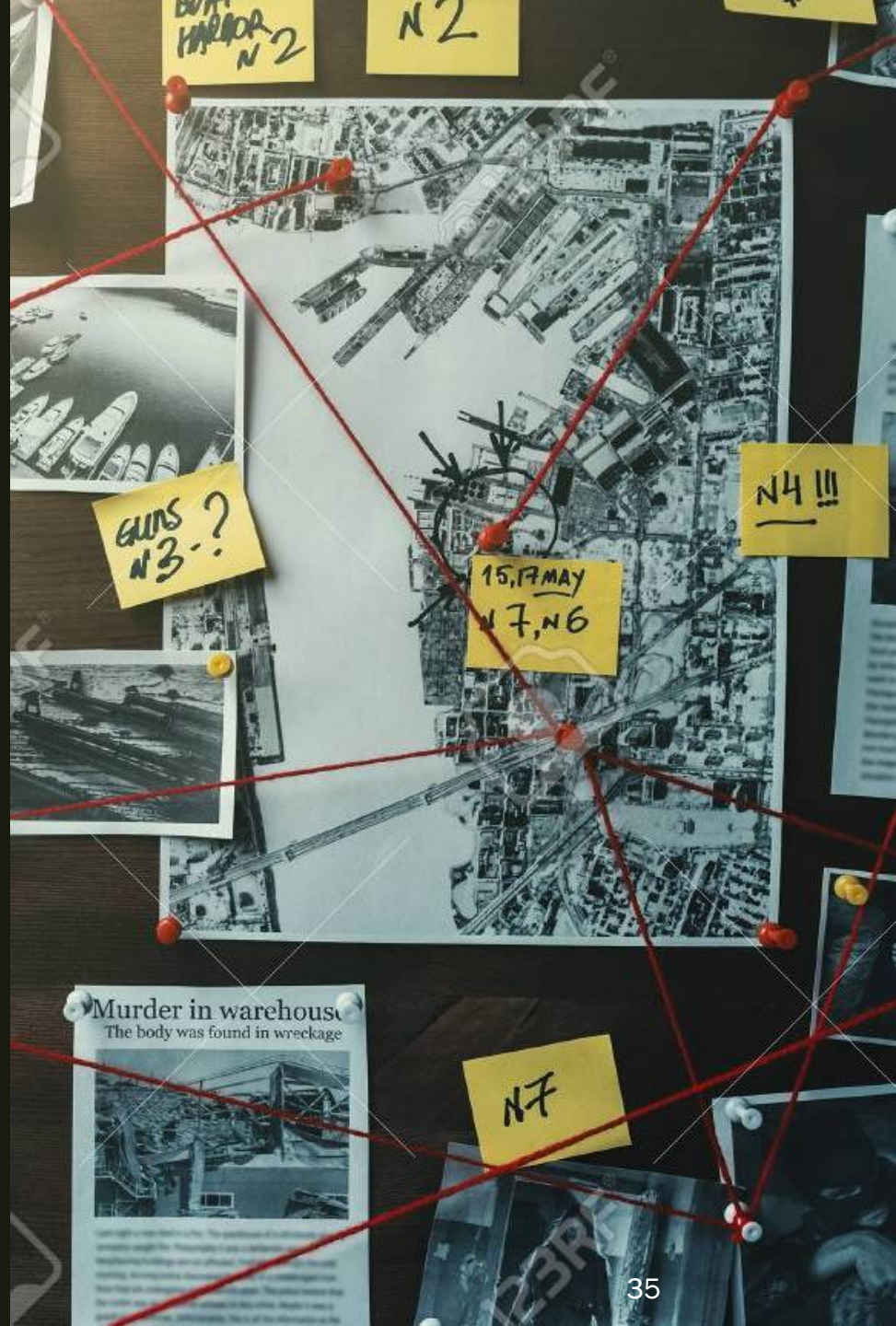
- Keep the problem from getting worse
- It may be appropriate to ..
  - *Shut down the system*
  - *Disconnect the system from the network*
  - *Disable certain affected functions of the system*
- What to consider
  - *Overall risk*
  - *CIA Triad (confidentiality, integrity, availability)*
  - *Evidence preservation requirements*
  - *Feasibility and effectiveness of containment*
  - *Duration of the strategy – temporary or permanent?*

Risk of containment

- Do you want to tip your hand?
  - *Some organizations may setup a sandbox and monitor the attacker*
  - *Some organizations may determine leaving everything online with stringent monitoring is a better short-term solution*
    - Further determine what's happening, what is affected
    - Dangerous solution – could lead to further compromise
- Might cause additional damage
  - *Removing internet access from some malware could cause it to behave differently*
    - Malware could start encrypting files when it loses connectivity
  - *Making changes could damage evidence*
    - May need evidence for determining the full scope of the incident
    - May need evidence for legal purposes

GATHERING EVIDENCE

- Especially in the case you need to preserve for legal proceedings, documentation is essential
- Talk with legal professionals to be sure your evidence can be admissible in court
- Account for evidence with a chain of custody
- Keep an evidence log
  - *Identifying information - location, model number, hostname, IP address, etc.*
  - *Who collected the evidence*
  - *Time and date*
  - *Evidence storage locations*
- *NIST SP 800-86, Guide to Integrating Forensic Techniques into Incident Response*



Create forensic images

- The quicker you can create a forensic image of the affected systems, the better
- Image the memory and filesystem
  - *You'll lose data if you turn off the system*
- Bit-by-bit images to get all filesystem data is best
- Create hashes of the original and images
- Not all incidents will allow for full backups and analysis
  - *More time sensitive incidents will require live forensics*

DIGITAL FORENSICS

DIGITAL FORENSICS

What did the attacker do?
How far did the attacker go?

Eradication

- Containment is to isolate and prevent spread; eradication is to remove
- Reformat and rebuild
- Restoring from CLEAN system backups

RECOVERY

- Fix vulnerabilities and improve defenses before placing back in production
- Monitor and assess

RECOVERY - MONITORING

- The other major portion of the recovery phase is continued monitoring
- Continually look for evidence of the intrusion
  - *On the recovered systems*
  - *On the entire network*
- Check regularly for re-compromise
  - *Script this!*
  - *Look for the specific indicators*
- Utilize network and host-based IPS/IDS
  - *Add indicators of the compromise*

PUBLIC RELATIONS / MEDIA RESPONSE

POST-INCIDENT ANALYSIS

Questions to address

- What happened?
- How well did the response work?
- Were documented procedures adequate?
- What other information could have been used sooner?
- What hurdles were there?
- What would you do differently next time?
- Could information sharing have been improved?
- What can we do next time to prevent any problems?
- How can we detect similar incidents in the future?
- Are any additional tools or resources needed?

NEXT